เอกสารประกอบการปฏิบัติการ
รายวิชา CP423324 Database and Web Security
Lab 6: Login/Logout และการจัดเก็บรหัสผ่าน

วัตถุประสงค์

1. เพื่อให้นักศึกษาสามารถสร้างระบบ Login และ Logout ด้วย PHP Session ได้
2. เพื่อให้นักศึกษาสามารถบันทึกรหัสผ่านด้วย password_hash() แทนการเก็บรหัสผ่านแบบข้อความธรรมดา
3. เพื่อให้นักศึกษาสามารถตรวจสอบรหัสผ่านด้วย password_verify()

คำชี้แจง

1. ให้นักศึกษา Capture ผลลัพธ์ตามที่งานของแต่ละข้อกำหนดลงใน Word และบันทึกไฟล์เป็น PDF โดยให้ตั้งชื่อว่า Lab06_รหัสนักศึกษา(มีขีด).pdf
2. เมื่อทำเสร็จเรียบร้อยแล้วให้แจ้งผู้ช่วยสอน (TA) เพื่อขอรับการตรวจและตอบคำถาม (กรุณาตรวจกับพี่ TA โดยคะแนนจะมาจากการตรวจในห้องเรียน)
3. เมื่อตรวจกับ TA เรียบร้อยแล้วให้นักศึกษาส่งใน Classroom เพื่อเป็นการสำรองข้อมูล
4. ไม่อนุญาตให้ส่งงานย้อนหลังได้ ยกเว้นกรณีลาป่วย หรืออุบัติเหตุ (ต้องมีใบรับรองแพทย์)

★★★★★★★★★★

โจทย์ที่กำหนด

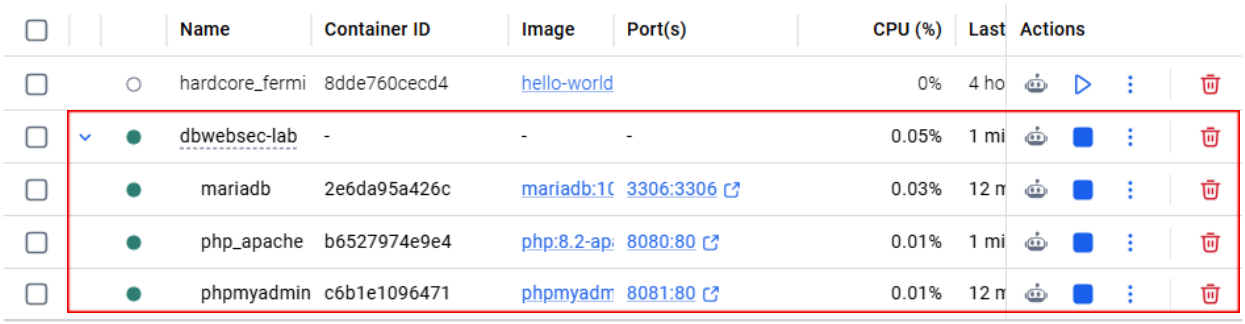
งานปฏิบัติการนี้ให้นักศึกษาพัฒนาเว็บแอปพลิเคชันสำหรับระบบเข้าสู่ระบบและออกจากระบบ โดยเริ่มจากการสร้างบัญชีผู้ใช้และจัดเก็บรหัสผ่านในรูปแบบ Hash ด้วย password_hash() เพื่อไม่ให้ฐานข้อมูลเก็บรหัสผ่านจริง จากนั้นระบบจะรับ Username และ Password จากแบบฟอร์ม Login ค้นหาข้อมูลผู้ใช้จากฐานข้อมูล และตรวจสอบรหัสผ่านด้วย password_verify() เมื่อเข้าสู่ระบบสำเร็จ ระบบจะสร้าง Session เพื่อจดจำสถานะและข้อมูลของผู้ใช้ระหว่างการใช้งาน พร้อมทั้งกำหนดให้แสดงหน้า profile.php ที่สามารถเข้าถึงได้เฉพาะผู้ที่ผ่านการ Login แล้วเท่านั้น หากผู้ใช้ยังไม่ได้ Login ระบบจะเปลี่ยนกลับไปยังหน้า Login และเมื่อกด Logout ระบบจะล้างข้อมูล Session และยกเลิกสถานะการเข้าสู่ระบบ

ลำดับการทำงานของระบบ

1. เปิด Lab06_create_user.php เพื่อสร้างผู้ใช้ตัวอย่าง
2. เปิด Lab06_login.php
3. เมื่อกรอกข้อมูลจะส่ง Username และ Password ไปยัง Lab06_login_process.php ค้นหาผู้ใช้จากฐานข้อมูล และใช้ password_verify() ตรวจสอบความถูกต้องของรหัสผ่าน
4. สร้าง Session และเข้าสู่ Lab06_profile.php
5. เมื่อกด Logout จะทำลาย Session ที่ Lab06_logout.php แล้วกลับไป Lab06_login.php

โดยมีขั้นตอนการสร้าง ดังนี้

1. เปิด docker ที่เคยสร้างไว้ ให้ Start container name: dbwebsec-lab, mariadb, php_apache และ phpmyadmin



Name	Container ID	Image	Port(s)	CPU (%)	Last	Actions
hardcore_fermi	8dde760cecd4	hello-world		0%	4 ho	
dbwebsec-lab	-	-	-	0.05%	1 mi	
mariadb	2e6da95a426c	mariadb:1(	3306:3306	0.03%	12 m	
php_apache	b6527974e9e4	php:8.2-ap	8080:80	0.01%	1 mi	
phpmyadmin	c6b1e1096471	phpmyadm	8081:80	0.01%	12 m	

2. การสร้างฐานข้อมูลและตารางผู้ใช้ ให้สร้างฐานข้อมูลชื่อ db_lab06 และตาราง users โดยมีโครงสร้างดังนี้

Field	Data Type	ข้อกำหนด	ความหมาย
id	INT	PRIMARY KEY, AUTO_INCREMENT	**รหัสผู้ใช้**
fullname	VARCHAR(100)	NOT NULL	**ชื่อ–นามสกุล**
username	VARCHAR(50)	NOT NULL, UNIQUE	**ชื่อผู้ใช้**
password_hash	VARCHAR(255)	NOT NULL	**รหัสผ่านที่ผ่านการ Hash**
role	VARCHAR(20)	NOT NULL, DEFAULT 'user'	**บทบาทของผู้ใช้**
created_at	TIMESTAMP	DEFAULT CURRENT_TIMESTAMP	**วันที่สร้างบัญชี**

ตัวอย่างคำสั่ง SQL

```
CREATE DATABASE db_lab06
CHARACTER SET utf8mb4
COLLATE utf8mb4_unicode_ci;
USE db_lab06;

CREATE TABLE users (
    id INT AUTO_INCREMENT PRIMARY KEY,
    fullname VARCHAR(100) NOT NULL,
    username VARCHAR(50) NOT NULL UNIQUE,
    password_hash VARCHAR(255) NOT NULL,
    role VARCHAR(20) NOT NULL DEFAULT 'user',
    created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP
);
```

3. ให้นักศึกษาสร้างโฟลเดอร์ Lab06 ไว้ภายใน C:\dbwebsec-lab\www สำหรับไฟล์ที่ต้องสร้างมีไฟล์ทั้งหมด 7 ไฟล์ มีรายละเอียด ดังนี้

1) Lab06_config.php สำหรับเชื่อมต่อฐานข้อมูล เริ่ม Session และเก็บฟังก์ชันที่ใช้ซ้ำ
2) Lab06_create_user.php สำหรับสร้างผู้ใช้ตัวอย่างและบันทึกรหัสผ่านด้วย password_hash()
3) Lab06_login.php สำหรับแสดงแบบฟอร์ม Username และ Password
4) Lab06_login_process.php สำหรับรับข้อมูล Login ค้นหาผู้ใช้ และตรวจสอบรหัสผ่านด้วย password_verify()
5) Lab06_profile.php สำหรับหน้าที่เข้าถึงได้เฉพาะผู้ใช้ที่ Login แล้ว
6) Lab06_auth_check.php สำหรับตรวจสอบ Session ก่อนอนุญาตให้เข้าหน้าป้องกัน
7) Lab06_logout.php สำหรับลบข้อมูล Session และกลับไปหน้า Login

3.1 ให้สร้างไฟล์ชื่อ Lab06_config.php เพื่อเก็บค่ากำหนดของระบบและฟังก์ชันที่ใช้ซ้ำ โดยไฟล์นี้จะถูกเรียกใช้จาก Lab06_create_user.php, Lab06_login.php, Lab06_login_process.php, Lab06_profile.php, Lab06_auth_check.php และ Lab06_logout.php

คำสั่งของ ไฟล์ Lab06_config.php มีดังนี้

```php
<?php
declare(strict_types=1);
const DB_HOST='db';
const DB_PORT=3306;
const DB_NAME='db_lab06';
const DB_USER='root';
const DB_PASS='root';
mysqli_report(MYSQLI_REPORT_ERROR | MYSQLI_REPORT_STRICT);
session_start();
try {
    $conn=new mysqli(DB_HOST,DB_USER,DB_PASS,DB_NAME,DB_PORT);
    $conn->set_charset('utf8mb4');
    $conn->query("SET time_zone = '+07:00'");
} catch (mysqli_sql_exception $e) {
    http_response_code(500);
    error_log($e->getMessage());
    exit('Database connection failed.');
}
function h(?string $value): string {
    return htmlspecialchars($value ?? '', ENT_QUOTES | ENT_SUBSTITUTE, 'UTF-8');
}
```

3.2 สร้างไฟล์ Lab06_create_user.php ไฟล์นี้ ใช้สร้างผู้ใช้ตัวอย่าง โดยต้องแปลงรหัสผ่านเป็น Hash ก่อนบันทึกลงฐานข้อมูล โดยห้ามบันทึกรหัสผ่านแบบข้อความธรรมดาลงฐานข้อมูล

ตัวอย่างข้อมูลที่กำหนดผู้ใช้ 2 บัญชี

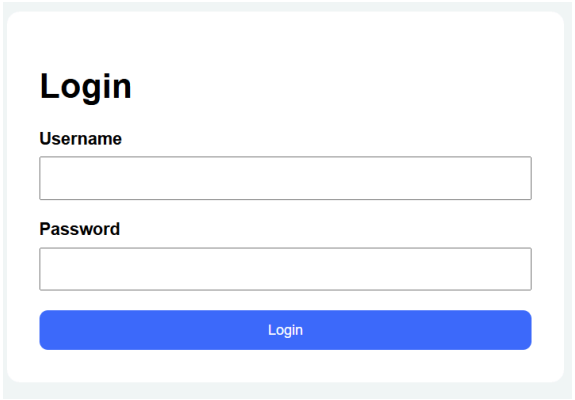
Full Name	Username	Password	Role
Administrator	admin	Admin1234	admin
Student	student	Student1234	user

```php
<?php
declare(strict_types=1);
require_once 'Lab06_config.php';
$users=[
 ['fullname'=>'Administrator','username'=>'admin','password'=>'Admin1234','role'=>'admin'],
 ['fullname'=>'Student','username'=>'student','password'=>'Student1234','role'=>'user']
];
$insertSql='INSERT INTO users (fullname,username,password_hash,role) VALUES (?,?,?,?)';
$insertStmt=$conn->prepare($insertSql);
$created=[];$skipped=[];
foreach($users as $user){
    $checkStmt=$conn->prepare('SELECT id FROM users WHERE username=?');
    $checkStmt->bind_param('s',$user['username']);
    $checkStmt->execute();
    if($checkStmt->get_result()->num_rows>0){
        $skipped[]=$user['username'];$checkStmt->close();continue;}
    $checkStmt->close();
    $hash=password_hash($user['password'],PASSWORD_DEFAULT);
    $insertStmt->bind_param('ssss',$user['fullname'],$user['username'],$hash,$user['role']);
    $insertStmt->execute();
    $created[]=$user['username'];
}
$insertStmt->close();
?>
<!doctype html>
<html lang="en">
<head>
    <meta charset="utf-8">
    <title>Create Users</title>
</head>
<body>
    <h1>Create Sample Users</h1>
    <?php if ($created): ?>
        <p>Created: <?= h(implode(', ', $created)) ?>
        </p>
    <?php endif; ?>
    <?php if ($skipped): ?>
        <p>Skipped existing users:<?= h(implode(', ', $skipped)) ?>
        </p>
    <?php endif; ?>
    <p>admin / Admin1234</p>
    <p>student / Student1234</p>
    <a href="Lab06_login.php">
        Go to Login
    </a>
</body>
</html>
```

3.3 สร้างไฟล์ Lab06_login.php โดยในหน้าจอจะประกอบด้วยดังนี้ (ให้นศ.เขียนคำสั่งเอง)

- การสร้างแบบฟอร์มที่ส่งข้อมูลไปยัง Lab06_login_process.php ด้วย method="post"
- มีช่อง Username และ Password
- Password ต้องใช้ input type="password"
- แสดงข้อความผิดพลาดเมื่อ Login ไม่สำเร็จ
- หาก Login อยู่แล้ว สามารถเปลี่ยนไปยัง Lab06_profile.php ได้

ตัวอย่างหน้าจอ



3.4 Lab06_login_process.php ใช้เมื่อ Login สำเร็จ ให้เรียก session_regenerate_id(true) โดยเก็บ user_id, fullname, username และ role ไว้ใน $_SESSION และไปเปลี่ยนไปยัง Lab06_profile.php แต่หาก Login ไม่สำเร็จ ให้กลับไป Lab06_login.php พร้อมข้อความว่าเข้าระบบไม่ได้

```php
<?php
declare(strict_types=1);
require_once 'Lab06_config.php';
if($_SERVER['REQUEST_METHOD']!=='POST'){
    header('Location: Lab06_login.php');
    exit;
    }
$username=trim($_POST['username'] ?? '');
$password=$_POST['password'] ?? '';
if($username==='' || $password===''){
    header('Location: Lab06_login.php?error=empty');
    exit;
    }
$sql='SELECT id,fullname,username,password_hash,role FROM users WHERE username=?';
$stmt=$conn->prepare($sql);
$stmt->bind_param('s',$username);
$stmt->execute();
$user=$stmt->get_result()->fetch_assoc();
$stmt->close();
if($user && password_verify($password,$user['password_hash'])){
    session_regenerate_id(true);
    $_SESSION['user_id']=(int)$user['id'];
    $_SESSION['fullname']=$user['fullname'];
    $_SESSION['username']=$user['username'];
    $_SESSION['role']=$user['role'];
    header('Location: Lab06_profile.php');exit;
}
header('Location: Lab06_login.php?error=1');exit;
```

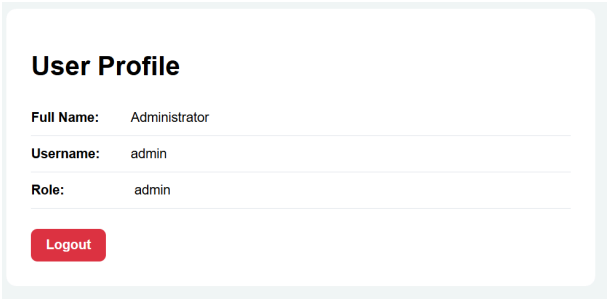
3.5 Lab06_auth_check.php **ไฟล์นี้เป็นการเขียนโค้ดตรวจสอบ** Session **เพื่อนำไปใช้ซ้ำในทุกหน้าที่ต้อง** Login **และใช้ตรวจสอบว่ามีข้อมูลผู้ใช้ใน** Session **หรือไม่ หากยังไม่ได้** Login **ให้กลับไปหน้า** Lab06_login.php

```php
<?php
declare(strict_types=1);
require_once 'Lab06_config.php';
if(!isset($_SESSION['user_id'])){
    header('Location: Lab06_login.php');
    exit;
    }
```

3.6 Lab06_profile.php **ให้ดำเนินการตามลำดับดังนี้ (ให้นศ.เขียนคำสั่งเอง)**

- เรียกใช้ Lab06_auth_check.php เป็นบรรทัดแรกก่อนแสดง HTML
- แสดงข้อความจากข้อมูลที่ได้จาก Session
- แสดง Username และ Role
- ข้อมูลที่นำมาแสดงต้องผ่าน h()
- มีลิงก์หรือปุ่ม Logout ไปยัง Lab06_logout.php

ตัวอย่างหน้าจอ



3.7 Lab06_logout.php **สำหรับล้างข้อมูล** Session **ทั้งหมดและกลับไปยังหน้า** Login

```php
<?php
declare(strict_types=1);
require_once 'Lab06_config.php';
$_SESSION=[];
if(ini_get('session.use_cookies')){
    $p=session_get_cookie_params();
    setcookie(session_name(),'',time()-42000,$p['path'],
    $p['domain'],$p['secure'],$p['httponly']);
}
session_destroy();
header('Location: Lab06_login.php');exit;
```

งานที่ 1.1 ให้กรอก URL http://localhost:8080/Lab06/Lab06_create_user.php
จากนั้น Capture หน้าจอผลลัพธ์ที่แสดง และเปิด phpMyAdmin และตรวจสอบข้อมูลในตาราง users จากนั้น Capture หน้าจอของ ตาราง User ถัดมาที่หน้าเว็บให้คลิกที่ Go to Login แล้ว Capture หน้าจอผลลัพธ์ที่แสดง

งานที่ 1.2 จากนั้นให้ Login ด้วยข้อมูลที่ถูกต้อง แล้ว Capture ผลลัพล์
Username: admin
Password: Admin1234
หรือ
Username: student
Password: Student1234
แล้วคลิกปุ่ม Login

งานที่ 2.1 ให้ Login ด้วยข้อมูลไม่ถูกต้อง ด้วยตัวอย่างข้อมูลตามด้านล่าง และ Capture หน้าจอผลลัพธ์ที่แสดง
ตัวอย่างการกรอกข้อมูล
Username: admin
Password: Admin123

ตัวอย่างการกรอกข้อมูล
Username: ว่าง
Password: ว่าง

งานที่ 2.2 ให้เปิด Lab06_profile.php โดยยังไม่ได้ Login

1) เปิด Browser แบบ Incognito หรือ Logout ออกจากระบบก่อน
2) พิมพ์ URL โดยตรง ดังนี้ http://localhost:8080/Lab06/Lab06_profile.php

งานที่ 2.3 การทดสอบ SQL Injection ในช่อง Username โดยให้กรอกข้อมูลดังนี้
Username: ' OR '1'='1
Password: anything
แล้วกดปุ่ม Login

งานที่ 3.1 ให้กรอก URL http://localhost:8080/Lab06/Lab06_login.php ให้ Login ให้ถูกต้อง จากนั้น เปิด Tab ใหม่ขึ้นมา แล้วใส่ URL : http://localhost:8080/Lab06/Lab06_login.php

จากนั้น Capture หน้าจอผลลัพธ์ที่แสดง

งานที่ 3.2 ให้กดปุ่ม Logout ของ Tab ที่ 1 จากนั้นไปที่ Tab ที่ 2 กด ปุ่ม Refresh จากนั้น Capture หน้าจอผลลัพธ์ที่แสดง

